

Vertrag zur Auftragsverarbeitung (AVV)

gemäß Art. 28 Abs. 3 Datenschutz-Grundverordnung (DSGVO)

Zwischen

[Name des Vereins / der GmbH]

[Straße, Hausnummer]

[PLZ, Ort]

– nachfolgend „Verantwortlicher“ genannt –

und

Mahad Daud Abdulle / CyclesGuard

[Deine Straße und Hausnummer]

[Deine PLZ] Frankfurt am Main

cyclesguard@proton.me

– nachfolgend „Auftragsverarbeiter“ genannt –

§ 1 Gegenstand und Zweck der Verarbeitung

Der Auftragsverarbeiter erbringt für den Verantwortlichen Dienstleistungen im Bereich der softwaregestützten Trainings- und Belastungssteuerung. Gegenstand dieses Vertrages ist die Verarbeitung personenbezogener Daten durch den Auftragsverarbeiter im Rahmen der Nutzung der SaaS-Plattform „CyclesGuard“ (gemäß Hauptvertrag / Pilot-Vereinbarung).

Zweck der Verarbeitung ist die datenschutzkonforme Erfassung von täglichen Check-ins der Spielerinnen zur Berechnung einer aggregierten Belastungs-Ampel (Grün, Gelb, Rot) für den Trainerstab.

§ 2 Dauer der Verarbeitung

Dieser Vertrag tritt mit Unterzeichnung in Kraft. Die Dauer der Verarbeitung richtet sich nach der Laufzeit des zugrundeliegenden Hauptvertrages (bzw. der Pilotphase). Er endet automatisch mit der Beendigung des Hauptvertrages.

§ 3 Art der Daten und Kreis der betroffenen Personen

(1) Art der verarbeiteten Daten:

- Personenstammdaten: Vorname, Nachname, E-Mail-Adresse, Trikotnummer (optional).
- Besondere Kategorien personenbezogener Daten (Art. 9 DSGVO): Gesundheits- und Zyklusdaten (tägliches Wohlbefinden, Symptome, Zyklusphasen).

Hinweis zur Zero-Knowledge-Architektur: Die unter Art. 9 DSGVO fallenden Daten werden auf den Servern des Auftragsverarbeiters ausschließlich algorithmisch verarbeitet. Dem Verantwortlichen (Trainerteam/Verein) werden technisch bedingt (via Row Level Security) ausschließlich aggregierte Handlungsempfehlungen (Ampel-Status) zur Verfügung gestellt, niemals die zugrundeliegenden Intimdaten.

(2) Kategorien betroffener Personen:

- Spielerinnen (Athletinnen) des Verantwortlichen
- Trainerstab und Vereinsadministratoren des Verantwortlichen

§ 4 Pflichten des Auftragsverarbeiters

1. Der Auftragsverarbeiter verarbeitet personenbezogene Daten ausschließlich auf dokumentierte Weisung des Verantwortlichen, es sei denn, er ist gesetzlich hierzu verpflichtet. Die Bereitstellung und der bestimmungsgemäße Betrieb der Software CyclesGuard gelten als dokumentierte Weisung.
2. Der Auftragsverarbeiter gewährleistet, dass sich die zur Verarbeitung der personenbezogenen Daten befugten Personen zur Vertraulichkeit verpflichtet haben oder einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen.
3. Der Auftragsverarbeiter unterstützt den Verantwortlichen nach Möglichkeit mit geeigneten technischen und organisatorischen Maßnahmen bei der Erfüllung von dessen Pflichten zur Beantwortung von Anträgen auf Wahrnehmung der Rechte betroffener Personen (z. B. Export- und Löschfunktionen innerhalb der Applikation).
4. Nach Abschluss der Erbringung der Verarbeitungsleistungen löscht der Auftragsverarbeiter nach Wahl des Verantwortlichen alle personenbezogenen Daten oder gibt sie zurück, sofern keine gesetzliche Verpflichtung zur Speicherung besteht.

§ 5 Inanspruchnahme von Unterauftragsverarbeitern

(1) Der Verantwortliche stimmt der Beauftragung der nachfolgenden Unterauftragsverarbeiter zu:

- Vercel Inc. (Hosting Frontend & API-Routing) – Serverstandort: EU (z. B. Frankfurt)
- Supabase Inc. (Datenbank, Authentifizierung & Storage) – Serverstandort: EU (z. B. Frankfurt)

(2) Der Auftragsverarbeiter schließt mit diesen Unterauftragsverarbeitern Verträge gem. Art. 28 Abs. 4 DSGVO ab und stellt sicher, dass dieselben Datenschutzpflichten, die in diesem Vertrag festgelegt sind, auch den Unterauftragsverarbeitern auferlegt werden. Wechsel der Unterauftragsverarbeiter werden dem Verantwortlichen rechtzeitig vorab mitgeteilt.

§ 6 Technische und organisatorische Maßnahmen (TOM)

Der Auftragsverarbeiter hat geeignete technische und organisatorische Maßnahmen (TOM) ergriffen, um ein dem Risiko angemessenes Schutzniveau zu gewährleisten, insbesondere hinsichtlich der Verarbeitung von Gesundheitsdaten (Art. 9 DSGVO). Die detaillierten Maßnahmen sind in Anlage 1 zu diesem Vertrag dokumentiert.

§ 7 Meldung von Datenschutzverletzungen

Der Auftragsverarbeiter meldet dem Verantwortlichen Verletzungen des Schutzes personenbezogener Daten unverzüglich, spätestens jedoch innerhalb von 24 Stunden nach Kenntniserlangung.

Unterschriften

Ort, Datum: _____

Unterschrift Verantwortlicher (Verein)

Ort, Datum: _____

Unterschrift Auftragsverarbeiter (Mahad Daud Abdulle)

Anlage 1: Technische und organisatorische Maßnahmen (TOM) der CyclesGuard Plattform

1. Zutritts- und Zugangskontrolle

- Das physische Hosting erfolgt in ISO-27001-zertifizierten Rechenzentren (AWS EU via Vercel/Supabase).
- Der administrative Zugang zu den Systemen ist durch starke Passwörter und Zwei-Faktor-Authentifizierung (2FA) geschützt.

2. Zugriffskontrolle (Das Kernstück)

- Row Level Security (RLS): Strikte Datenbank-Policies auf Supabase-Ebene stellen sicher, dass Trainer-Accounts technisch keinen Lesezugriff (Read-Access) auf die Datenbank-Spalten der rohen Zyklus- und Symptom-Logs haben.
- Zero-Knowledge-Aggregation: Die Transformation der Athletinnen-Eingaben in den Ampel-Status erfolgt automatisiert und server-seitig; die Rohdaten verlassen die Datenbank nicht in Richtung des Vereins-Dashboards.

3. Weitergabekontrolle & Verschlüsselung

- Sämtliche Datenübertragungen zwischen Endgerät und Server erfolgen verschlüsselt (TLS 1.3).
- Ruhende Daten in der Datenbank (Data at Rest) werden mittels AES-256 verschlüsselt gespeichert.

4. Eingabekontrolle

- Das System protokolliert, wer welche Daten eingegeben oder verändert hat (z. B. Zeitstempel bei der Eingabe der täglichen Logs oder beim Hinzufügen/Entfernen von Spielerinnen durch den Admin).

5. Verfügbarkeitskontrolle & Belastbarkeit

- Verwendung robuster Cloud-Infrastrukturen (Next.js Edge Network, Supabase Managed Database) mit automatisierten Backups zur Sicherstellung der Datenverfügbarkeit.

6. Trennungsgebot

- Die Daten unterschiedlicher Verantwortlicher (Mandanten/Clubs) werden durch strikte Tenant-IDs und RLS-Richtlinien logisch strikt voneinander getrennt verarbeitet. Cross-Club-Zugriffe sind technisch ausgeschlossen.